Supplementary material

Aligning cybersecurity investment with business-impact risk: A knowledge-based AI decision-support model evaluated on real-world incident data

Rahul Chandra Nandagiri

All tables below are produced by run_experiment.py in the public repository (https://github.com/rahulchandranandagiri/cybersecurity-investment-business-performance) and are also provided there as CSV files in results/tables/. Unless stated otherwise, decision results use the reference budget ($B = 9$, $\alpha = \beta = 1$) and the 18 sector–size profiles of the 2017–2026 evaluation period.

Table S1. Knowledge base: production rules mapping VERIS incident patterns to control families (R1–R22) and expert consequence rules (C1–C3). An incident's family weights are the normalized counts of the rules it triggers.

Rule	Scope	Condition	Family / consequence
R1	hacking	Use of stolen creds / brute force / credential stuffing	F1
R2	hacking	Exploit vuln, SQLi, XSS, forced browsing, abuse of functionality	F2
R3	hacking	Backdoor or command-and-control use	F4
R4	hacking	Denial of service	F5
R5	hacking	Unknown variety via web application	F2
R6	hacking	Unknown variety via remote access / desktop sharing / VPN	F1
R7	hacking	Unknown variety via backdoor	F4
R8	hacking	Unknown variety and vector	F1, F2
R9	malware	Any malware	F4
R10	malware	Ransomware or data destruction	F5
R11	malware	Delivered by e-mail or web (attachment, link, drive-by)	F3
R12	malware	Remote injection	F2
R13	social	Bribery of insiders only	F7
R14	social	Phishing, pretexting and other social engineering	F3
R15	misuse	Any insider misuse (privilege, possession, knowledge abuse)	F7
R16	misuse	Data mishandling	F6
R17	error	Misconfiguration, programming error, malfunction	F2
R18	error	Misdelivery, publishing, disposal, loss and other handling errors	F6
R19	physical	Any physical action (theft, skimmer, tampering, snooping)	F8
R20	physical	Theft of user devices or media (encryption gap)	F6
R21	environmental	Fire, power failure, natural hazard	F5
R22	actor	Partner actor or partner vector	F9
C1	consequence	Ransomware, destructive malware, DoS or environmental event	disrupt
C2	consequence	Hacking of server-side data stores, data-capturing malware, or misconfiguration/publishing of server data	mass

Rule	Scope	Condition	Family / consequence
C3	consequence	Handling error (misdelivery, disposal, loss, gaffe), or physical or misuse action without hacking	contained

Source: decision_intelligence.py (RULES, family_weights, consequence_rules).

Table S1b. Control families and their alignment with CIS Critical Security Controls v8 and NIST CSF 2.0 categories.

Family	Name	CIS v8 / NIST CSF 2.0
F1	Identity & access management	CIS 5-6; PR.AA
F2	Vulnerability & secure configuration	CIS 4, 7, 16; ID.RA, PR.PS
F3	Email/web protection & awareness	CIS 9, 14; PR.AT
F4	Malware defense & threat detection	CIS 10, 13; DE.CM
F5	Backup, recovery & resilience	CIS 11, 17; RC.RP, PR.IR
F6	Data protection & handling	CIS 3; PR.DS
F7	Insider & privileged-activity monitoring	CIS 6, 8; DE.CM
F8	Physical & asset security	CIS 1-2; PR.AA-06
F9	Third-party & supply-chain risk	CIS 15; GV.SC

Table S2. Business-impact risk reduction (BIRR) by profile at the reference budget.

Profile	Equal	Threat freq. (context)	Impact-aligned (pooled)	KB-CIDS w/o AI imputation	KB-CIDS	Oracle
Administrative services, Large	0.500	0.412	0.472	0.532	0.527	0.604
Administrative services, Small	0.500	0.575	0.609	0.644	0.638	0.734
Education, Large	0.500	0.426	0.505	0.564	0.550	0.602
Education, Small	0.500	0.406	0.534	0.598	0.580	0.704
Finance & insurance, Large	0.500	0.580	0.601	0.597	0.602	0.648
Finance & insurance, Small	0.500	0.459	0.519	0.573	0.559	0.656
Healthcare, Large	0.500	0.375	0.443	0.536	0.518	0.595
Healthcare, Small	0.500	0.380	0.488	0.568	0.541	0.628
Information, Large	0.500	0.558	0.617	0.653	0.647	0.679
Information, Small	0.500	0.571	0.632	0.677	0.662	0.695
Manufacturing, Large	0.500	0.462	0.542	0.592	0.580	0.639
Manufacturing, Small	0.500	0.471	0.530	0.604	0.588	0.662
Professional services, Large	0.500	0.424	0.524	0.580	0.563	0.648
Professional services, Small	0.500	0.532	0.620	0.665	0.651	0.730
Public administration, Large	0.500	0.523	0.545	0.539	0.548	0.558
Public administration, Small	0.500	0.459	0.542	0.586	0.568	0.619
Retail & wholesale, Large	0.500	0.501	0.579	0.625	0.613	0.674
Retail & wholesale, Small	0.500	0.586	0.644	0.647	0.650	0.731

Table S3. Weighting parameters selected on the inner validation split (training up to 2014, validation 2015–2016) and the corresponding validation BIRR.

Strategy	λ_s	λ_g	Half-life *h* (years)	Validation BIRR
KB-CIDS (full)	1	0.5	1	0.5601
KB-CIDS w/o context	1	∞	1	0.5585
KB-CIDS w/o recency	1	0.5	∞	0.5516
KB-CIDS w/o AI imputation	0.25	0.2	1	0.5414
Impact-aligned (pooled)	1	∞	∞	0.5300
Threat frequency (context)	0.25	1	0.5	0.4871
Threat frequency (pooled)	1	∞	∞	0.4534

∞ denotes no weighting on that dimension (pooled context or no recency discount). The full grid is in S3_validation_tuning.csv.

Table S4. Mean BIRR across profiles as a function of the budget relative to the reference budget.

B / B_{ref}	Equal	Threat freq. (context)	Impact-aligned (pooled)	KB-CIDS	Oracle
0.10	0.091	0.104	0.170	0.190	0.224
0.18	0.151	0.155	0.239	0.264	0.313
0.32	0.240	0.224	0.321	0.360	0.420
0.56	0.360	0.333	0.425	0.467	0.538
1.00	0.500	0.483	0.553	0.588	0.656
1.78	0.640	0.628	0.678	0.703	0.761
3.16	0.760	0.752	0.785	0.802	0.845
5.62	0.849	0.844	0.865	0.876	0.905
10.00	0.909	0.906	0.919	0.925	0.943

Table S5. Sensitivity of mean BIRR to the Gordon–Loeb parameters α and β at the reference budget.

α	β	Equal	Threat freq. (context)	KB-CIDS	Oracle	KB-CIDS gap closed (%)
0.5	1	0.333	0.308	0.444	0.513	61.5
0.5	2	0.556	0.538	0.656	0.732	57.0
0.5	3	0.704	0.692	0.779	0.845	53.3
1	1	0.500	0.483	0.588	0.656	56.5
1	2	0.750	0.740	0.807	0.862	50.8
1	3	0.875	0.870	0.907	0.942	47.2
2	1	0.667	0.656	0.725	0.781	51.5
2	2	0.889	0.885	0.914	0.944	46.4
2	3	0.963	0.961	0.972	0.985	43.2

Table S6. Robustness of the decision results to alternative specifications (each specification re-tunes on its own inner validation split).

Specification	Profiles	Equal	Threat freq.	Impact pooled	w/o AI imp.	KB-CIDS	Oracle	Gap closed (%)	p vs threat freq.
Main specification	18	0.500	0.483	0.553	0.599	0.588	0.656	56.5	<0.001
Record threshold 100,000	17	0.500	0.477	0.592	0.614	0.615	0.671	66.8	<0.001
Excluding non-random sub-sources	8	0.500	0.421	0.482	0.553	0.550	0.645	34.3	0.008
Split year 2015	20	0.500	0.457	0.520	0.554	0.565	0.644	45.6	<0.001
Split year 2017	16	0.500	0.488	0.570	0.617	0.604	0.659	65.2	<0.001
Profiles with >= 5 material incidents	22	0.500	0.478	0.551	0.599	0.588	0.665	53.4	<0.001

p from two-sided Wilcoxon signed-rank tests of KB-CIDS against context-weighted threat-frequency allocation.

Table S7. Permutation importance of the KB-CIDS materiality model on the evaluation period (mean drop in ROC-AUC over 10 repeats; top 15 features).

Feature	Mean ΔAUC	SD
kb_F5	0.0737	0.0093
asset=S - Database	0.0350	0.0018
asset=M - Documents	0.0161	0.0038
sector=Healthcare	0.0111	0.0018
kr_contained	0.0107	0.0018
sector=Information	0.0101	0.0020
kb_F3	0.0058	0.0016
asset=S - Mail	0.0055	0.0009
asset=M - Payment card	0.0054	0.0017
asset=T - ATM	0.0046	0.0009
asset=S - File	0.0043	0.0009
region=US	0.0033	0.0009
asset=S - Unknown	0.0032	0.0015
sector=Administrative services	0.0026	0.0010
kb_F2	0.0026	0.0008

kb_F1–kb_F9 are knowledge-base family weights; kr_disrupt, kr_mass and kr_contained are expert consequence-rule flags.

Table S8. Allocation rationale for small healthcare organizations: the threat patterns contributing most of each family's business-impact risk (development-period evidence, KB-CIDS weights).

Family	Threat pattern	Share of family risk (%)
F1	hacking:Unknown	62.4
F1	hacking:Use of stolen creds	9.0
F1	hacking:Unknown + malware:Ransomware	5.7
F2	hacking:Unknown	62.0
F2	error:Misconfiguration	9.3
F2	hacking:SQLi	7.0
F3	social:Phishing	20.4

Family	Threat pattern	Share of family risk (%)
F3	malware:Ransomware + social:Phishing	18.9
F3	malware:Unknown + social:Phishing	10.5
F4	malware:Ransomware	34.3
F4	malware:Unknown	11.8
F4	hacking:Unknown + malware:Ransomware	5.8
F5	hacking:DoS	40.5
F5	malware:Ransomware	34.5
F5	hacking:Unknown + malware:Ransomware	5.8
F6	error:Publishing error	26.3
F6	physical:Theft	24.7
F6	error:Misdelivery	20.8
F7	misuse:Privilege abuse	61.9
F7	social:Bribery + misuse:Privilege abuse	8.0
F7	misuse:Data mishandling	5.9
F8	physical:Theft	57.9
F8	physical:Tampering	17.5
F8	physical:Skimmer	9.6
F9	error:Publishing error	26.0
F9	error:Disposal error	12.9
F9	error:Misdelivery	8.3

Table S9. Mean budget shares (%) by control family across the 18 profiles, compared with the realized shares of material-impact risk in 2017–2026.

Allocation	F1	F2	F3	F4	F5	F6	F7	F8	F9
Threat frequency, context-weighted	7.9	19.9	4.1	5.5	3.1	26.6	17.9	14.5	0.4
KB-CIDS	12.6	28.7	5.4	10.9	12.6	15.0	7.5	7.0	0.3
Realized risk share 2017–2026	12.0	41.4	5.0	16.3	13.9	5.9	2.9	1.5	1.1

Table S10. Out-of-time predictive metrics with 95% bootstrap confidence intervals (2,000 resamples).

Model	PR-AUC [95% CI]	Brier [95% CI]	ECE [95% CI]
Historical lookup (action category)	0.759 [0.728–0.791]	0.288 [0.273–0.303]	0.270 [0.246–0.298]
Expert consequence rules (Platt-calibrated)	0.861 [0.840–0.882]	0.194 [0.183–0.206]	0.188 [0.166–0.212]
Logistic regression	0.906 [0.887–0.923]	0.189 [0.176–0.202]	0.181 [0.159–0.204]
Random forest	0.915 [0.897–0.930]	0.176 [0.166–0.187]	0.180 [0.159–0.201]
Gradient boosting (no knowledge features)	0.928 [0.911–0.942]	0.150 [0.138–0.162]	0.118 [0.098–0.139]
KB-CIDS materiality model	0.932 [0.915–0.946]	0.151 [0.139–0.162]	0.130 [0.111–0.152]